

Privacy Inspector — Relatório

Disciplina: Segurança — Insper **Aluno:** Gustavo Valente **Repositório:** *(preencher com o link após o push)* **Plugin:** extensão Firefox (Manifest V2), carregada via `about:debugging` → "Carregar extensão temporária" → `src/manifest.json`.

Este relatório contém os entregáveis 2 (DuckDuckGo Privacy Test Pages), 3 (análise de 3 sites reais) e 4 (pontuação de privacidade). Prints, arquivos HAR e JSONs estão na pasta `evidencias/` do repositório.

Entregável 2 — Execução nas DuckDuckGo Privacy Test Pages

Ambiente: Firefox 156.0.1 (macOS), perfil limpo criado pelo harness `tools/capture_ddg.py`, com as proteções nativas do Firefox desligadas (Enhanced Tracking Protection, partição de cookies/estado de rede, query stripping, bounce tracking protection, resistFingerprinting) para que o plugin observe o tráfego sem interferência do navegador. Plugin carregado como extensão temporária. Data: 28–29/09/2026.

Para cada página: o **resultado esperado** é o que a própria página reporta (texto na tela e, quando existe, o JSON gerado pelo botão "Download the result", salvo em `evidencias/ddg/NN-*-resultado-pagina.json`). O **resultado do plugin** vem do JSON exportado pelo plugin (`evidencias/ddg/NN-*.json`). O print `evidencias/ddg/NN-*.png` mostra a página de teste (esquerda) e o relatório do plugin para aquela aba (direita).

#	Página	Resultado esperado (reportado pela página)	Resultado do plugin	Divergência e explicação
1	Tracker Reporting — 1 major tracker via <code><script></code>	A página carrega um script de <code>doubleclick.net</code> ; não há resultado dinâmico, o texto apenas descreve o teste.	1 domínio de 3ª parte, <code>doubleclick.net</code> , classificado como rastreador (Google / anúncios), tipo <code>script</code> , 1 requisição. Nota 92 (A).	Sem divergência.
2	Tracker Reporting — 1 major tracker via <code></code>	Carrega um pixel de <code>facebook.com/tr</code> .	1 domínio de 3ª parte, <code>facebook.com</code> (Meta / social), tipo <code>image</code> . A resposta trouxe <code>Set-Cookie: fr=...</code> persistente, contado como 1 cookie de 3ª parte injetado via HTTP . Nota 88 (A).	Sem divergência. O cookie <code>fr</code> não faz pa que a página reporta, mas está no HAR-equivalente do plugin (<code>cookies.setHead</code>
3	Tracker Reporting — 1 major tracker via <code>fetch</code> (5 s de atraso)	Após 5 s a página faz <code>fetch</code> para <code>facebook.com</code> .	1 domínio de 3ª parte, <code>facebook.com</code> , tipo <code>xmlhttprequest</code> (é como o Firefox classifica <code>fetch</code> no <code>webRequest</code>), com <code>Set-Cookie: fr</code> . Nota 88 (A).	Sem divergência. O harness espera 10 s de ler o relatório, cobrindo o atraso de 5 s
4	Tracker Reporting — 1 major tracker com surrogate	A página carrega um script de <code>doubleclick.net</code> que o DuckDuckGo substituiria por um <i>surrogate</i> (versão inócua).	1 domínio de 3ª parte, <code>doubleclick.net</code> , tipo <code>script</code> . Nota 92 (A).	Divergência esperada: o plugin apenas c e reporta; não implementa surrogates. Co Firefox estava sem proteção, o script real carregado e o plugin registrou a requisiçã <code>doubleclick.net</code> .
5a	Tracker Blocking (request blocking) — sem lista de bloqueio	JSON da página: 11 mecanismos <code>loaded</code> (<code>script</code> , <code>style</code> , <code>img</code> , <code>picture</code> , <code>object</code> , <code>audio</code> , <code>video</code> , <code>iframe</code> , <code>@import</code> , <code>font</code> , <code>background</code>) e <code>websocket: not loaded</code> .	11 requisições a <code>bad.third-party.site</code> (<code>script</code> 1, <code>stylesheet</code> 2, <code>object</code> 1, <code>sub_frame</code> 1, <code>image</code> 2, <code>imageset</code> 1, <code>font</code> 1, <code>media</code> 2), domínio classificado como rastreador (lista de teste do DDG). <code>WebSocket wss://bad.third-party.site/block-me/web-socket</code> detectado na aba Hijacking (nível médio: canal persistente para terceiro). Nota 88 (A).	Os 11 recursos batem 1:1 com os 11 loa página. WebSocket: a página reporta no loaded mesmo sem bloqueio (o <code>onopen</code> disparou dentro do timeout do teste), e o <code>webRequest</code> não recebeu evento de tipo <code>websocket</code> para essa conexão; o plugin viu pelo hook do construtor <code>WebSocket</code> n content script. Por isso o <code>WebSocket</code> apar Hijacking e não na contagem de requisiçõ
5b	Tracker Blocking — com <code>bad.third-party.site</code> na lista de bloqueio	JSON da página: todos os 12 mecanismos deixam de carregar (11 <code>not loaded</code> , <code>background: failed</code>).	12 bloqueios: 11 requisições canceladas em <code>webRequest.onBeforeRequest ({cancel:true})</code> + 1 <code>WebSocket</code> recusado no construtor (chip "bloqueado" na aba Hijacking). Contadores da aba Rastreadores mostram 11 req. / 11 bloq.	Sem divergência de resultado. A diferença rótulo (<code>not loaded</code> × <code>failed</code>) é da próp página: ela só marca <code>failed</code> quando o elemento dispara <code>error</code> ; para requisições canceladas pelo <code>webRequest</code> o Firefox não dispara <code>error</code> na maioria dos elementos, apenas no <code>background-image</code> via CSS.
6	Storage blocking	Texto: "Retrieved data from 23 storage mechanisms (2 failed)". JSON: 54 entradas; 43 com o valor gravado (39), 11 <code>null</code> — as <code>null</code> são APIs não suportadas no Firefox (<code>WebSQL</code> , <code>CookieStore</code> , <code>cookieStore</code> em service worker) e 2 falhas reais (<code>safe third party iframe - sessionStorage</code> , <code>ad third party iframe - first party header cookie</code>).	66 requisições (52 a terceiros); frames de 3ª parte em <code>good.third-party.site</code> , <code>broken.third-party.site</code> e <code>convert.ad-company.site</code> . Storage: <code>localStorage</code> 4 escritas/4 leituras, <code>sessionStorage</code> 4/4, <code>IndexedDB</code> 6 aberturas, <code>Cache API</code> 8 — todas com chave <code>data</code> e com uso em frames de 3ª parte . Cookies: 9 <code>Set-Cookie</code> (8 de terceiros), 14 via <code>document.cookie</code> (9 em frames de terceiros), 24 no <code>cookie jar</code> (17 de 3ª parte, 15 com validade > 1 ano). Nota 68 (C).	Concordância no essencial: cada mecanis que a página conseguiu usar tem o event correspondente no plugin (ex.: <code>top_tracker_headerdata = Set-Cookie broken.third-party.site; jsdata</code> e frame de <code>ad-company.site = document.cookie</code> de 3ª parte). Não observados pelo plugin: <code>window.name</code> , <code>history</code> , <code>memory</code> , "browser cache" e se worker — não são APIs de storage instrumentadas (são canais de persistência indiretos), e a <code>Cache API</code> só é vista no op não em <code>put/match</code> . Só o plugin viu: os cookies de 3ª parte já presentes no jar e a validade de 400 dias dos cookies <code>jsdata</code> informação que a página não reporta.
7	Storage partitioning (acessada via <code>www.first-party.site</code>)	JSON: 12 mecanismos <code>fail</code> (<code>document.cookie</code> , <code>HTTP cookie</code> , <code>Cookie Store</code> , <code>localStorage</code> , <code>sessionStorage</code> , <code>IndexedDB</code> , <code>Cache API</code> , <code>ServiceWorker</code> , <code>BroadcastChannel</code> , <code>SharedWorker</code> , <code>Web Locks</code>), 2 <code>pass</code> (<code>Font cache</code> , <code>HSTS</code>), 1 <code>unsupported</code> (<code>WebSQL</code>), 6 <code>error</code> (<code>caches</code> de <code>fetch/XHR/iframe/imagem/favicon/CSS/prefetch</code>). <code>fail</code> = não particionado (o dado gravado em um site foi lido em outro).	Na aba de <code>www.first-party.site</code> : storage só em frames de 1ª parte (<code>localStorage</code> 3/3, <code>sessionStorage</code> 2, <code>IndexedDB</code> 1, <code>Cache</code> 1 com chave <code>partition_test</code>), 3 requisições de imagem a <code>privacy-test-pages.site</code> , 7 cookies de 3ª parte de <code>privacy-test-pages.site</code> no jar. A aba Bounce/Sync registra 1 popup aberto pela página : <code>testWindow.html?sessionId=...&isLocalTest=false</code> . Nota 79 (B).	Divergência esperada, por dois motivos: Os <code>fail</code> são consequência do perfil: o he desliga a partição de estado do Firefox (<code>privacy.partition.network_state= cookieBehavior=0</code>), então de fato não l partição — a página está certa e o plugin mede partição, apenas quem acessa store A metade <i>cross-site</i> do teste roda em uma segunda janela (<code>testWindow.html</code>), qu <code>tabId</code> próprio; o plugin gera relatório por então os acessos cross-site ficam no relat outra aba. O plugin registra a abertura da para tornar isso rastreável. Os 7 cookies c parte de <code>privacy-test-pages.site</code> sã gravados no teste 6 e lidos aqui cross-site exatamente o que "não particionado" signi

#	Página	Resultado esperado (reportado pela página)	Resultado do plugin	Divergência e explicação
8	Fingerprinting (geral)	JSON: 124 datapoints coletados (headers, navigator.*, screen.*, canvas, WebGL, áudio, fontes, etc.).	Nível provável : canvas 5 leituras (3 após fillText com área ≥ 16×16), WebGL (getSupportedExtensions, getShaderPrecisionFormat), áudio (6× new OfflineAudioContext), fontes (692 measureText), enumeração de 23 propriedades (navigator.userAgent/hardwareConcurrency/plugins/mimeTypes/..., screen.*, getTimezoneOffset, enumerateDevices, getVoices). Nota 82 (B).	Concordância: a página é, por construção fingerprinter, e o plugin classificou como "provável". Parcial : o plugin instrumenta ~124 propriedades (as de maior entropia e usadas pela heurística do Blacklight). Não headers HTTP, window.innerWidth/outerWidth/devicePixelRatio, performance.memory etc.; é uma escolha de custo/benefício — em accessor por propriedade têm custo e propriedades de baixa entropia não muda veredito.
9	Fingerprinting — canvas verification (? run)	Tabela de status: bateria de checagens de <i>resistência e performance</i> de canvas (pass/fail para "layering comparison", "random noise", "fp example"...). Em Firefox sem proteção, os testes de resistência dão fail (nenhum ruído aplicado) e os de performance pass.	Canvas: 125 leituras (getImageData em canvas 2000×2000 e canvas de exemplo de fingerprint), 102 classificadas como fingerprint (texto desenhado + leitura). Nível provável. Nota 81 (B).	Concordância: a página executa exatamente o padrão que a heurística detecta (desenha texto/figuras e lê os pixels). As 23 leituras marcadas como fingerprint são as dos car "random noise" (sem fillText), o que n a heurística discriminando.
10	Bounce tracking — link "Go to privacy-test-pages.site"	A página de destino recebe ? bounceUIDlocalStorage=&bounceUIDcookie=&isNew=100 e mostra "ID didn't exist and was generated – 100": bad.third-party.site gerou um UID, tentou persistir e o repassou pela URL.	Aba Bounce/Sync: 1 bounce client-side por bad.third-party.site (permanência 0,15 s, privacy-test-pages.site → privacy-test-pages.site), parâmetros repassados ao destino (isNew=100, ...) e evidência do que a página de passagem fez: document.cookie = bounceUID=100; max-age=5184000 (60 dias) e localStorage.bounceUID. Nota 94 (A).	Sem divergência. Detalhe técnico: o redirecionamento é feito por JavaScript (n 3xx), por isso a "cadeia de redirecionamento está vazia e a detecção usa o critério de permanência curta em domínio intermediário eventos da página de passagem chegam background depois da navegação (flush n pagehide) e são anexados ao bounce p URL do frame.
11a	Query parameters — link com utm_source + parâmetro normal	Página de destino: "utm_source=something&q=other" (esperado pelo DDG após stripping: "q=other").	Parâmetro de rastreamento na URL da página: utm_source. Nota 97 (A).	Divergência esperada : o DDG espera q navegador <i>remove</i> o parâmetro; o plugin <i>re</i> reescreve URLs (é um observador) e o Firefox estava com privacy.query_stripping desligado, então o parâmetro chegou intacto; o plugin sinaliza a presença, que é o que se fazer sem alterar a navegação.
11b	Query parameters — link com fbclid	Página de destino: "fbclid=12345&fb_source=something&u=14" (esperado: "u=14").	Parâmetro de rastreamento na URL: fbclid. fb_source não está na lista do plugin. Nota 97 (A).	Mesma explicação de 11a. fb_source não reconhecido: a lista do plugin cobre os identificadores de clique (fbclid, gclid, msclickid, utm_*...), não parâmetros de sem identificador.
12	js-leaks (alterações em objetos globais), referência firefox_92	JSON: 835 propriedades adicionadas , 17 removidas , 3 alteradas (navigator.languages[0], location.toString, location.valueOf).	Hijacking: nível nenhum; 0 funções nativas sobrescritas; 2 globais novos (collectedProps, results, criados pela própria página). Fingerprint: "possível" por enumeração de 21 propriedades de navigator/screen. Nota 90 (A).	Duas leituras. (a) A página não detecta o plugin : as 835/17/3 diferenças são todas Firefox 92 (perfil de referência do DDG) e 156 — nenhuma envolve as APIs que o plugin substitui (toDataURL, getImageData, Storage.setItem, document.cookie, addEventListener, WebSocket...). Isso acontece porque os hooks são instalados exportFunction, que produz funções não do ponto de vista da página (Function.prototype.toString retorna [native code]). (b) O plugin não detecta a página como hijacking , corretamente: ele o objeto global, não sobrescreve nada. O "possível fingerprinting" é um falso positivo previsível — enumerar window inteiro toc propriedades que o plugin monitora.

Síntese

- **Cobertura**: o plugin reproduziu os resultados da página em todos os testes de rastreadores (1–5), storage (6), fingerprinting (8–9), bounce (10) e query parameters (11), e produziu o comportamento correto em 12.
- **Divergências estruturais** (não são erros de detecção): o plugin é um *observador*, não um *bloqueador por padrão* — não aplica surrogates (4), não remove query parameters (11) e não particiona storage (7). O bloqueio existe apenas pela lista personalizada (5b).
- **Limite de arquitetura**: relatório por aba. Testes que abrem janelas secundárias (7) espalham a evidência em dois relatórios; o plugin registra a janela aberta para permitir a correlação.
- **Limite de instrumentação**: WebSocket só é visto pelo hook do construtor quando o handshake não passa pelo `webRequest` (5a); canais de persistência indiretos (window.name, history, cache HTTP) não são instrumentados (6).

evidencias/ddg/NN-*.png

Metodologia da pontuação de privacidade

A nota parte de **100 pontos** e sofre deduções por critério. Cada critério tem um **teto**, para que um único eixo (ex.: um site com 40 domínios de anúncios) não zere a nota sozinho e para que sites com problemas em *vários* eixos sejam penalizados mais que sites com um único problema grande.

Critério	Dedução	Teto	Justificativa
Rastreadores conhecidos de 3ª parte (lista interna)	4 por domínio	32	É o indicador mais direto de vigilância comercial; corresponde aos "ad trackers" do Blacklight.
Outros domínios de 3ª parte (não listados)	1 por domínio	8	CDNs e APIs também recebem IP, referer e user-agent, mas sem intenção declarada de rastrear. Peso baixo.
Cookies de 3ª parte	2 por cookie	16	Mecanismo clássico de rastreamento entre sites; o Blacklight reporta a mesma contagem.
Cookies persistentes com validade > 1 ano	1 por cookie	6	Longevidade aumenta a janela de correlação de comportamento.
Fingerprinting	15 (provável) / 7 (possível)	15	Não pode ser apagado pelo usuário como um cookie; "provável" segue a heurística de Englehardt & Narayanan (texto desenhado + leitura ≥ 16x16), a mesma do Blacklight.
Gravação de sessão / heatmap	10	10	Captura movimentos, cliques e, por vezes, conteúdo digitado (Hotjar, FullStory, Clarity...). Blacklight: "session recorders".
Captura de teclado por script de 3ª parte	10	10	Listener de <code>keydown/keyup/input</code> em <code>document/window</code> registrado por script de outro domínio. Blacklight: "key logging".
Pixel do Facebook/Meta	6	6	Destacado separadamente pelo Blacklight por permitir vincular a navegação a um perfil social real.
Remarketing Google (DoubleClick / Google Ads)	4	4	Idem, categoria própria no Blacklight ("Google Analytics remarketing").
Cookie sync / vazamento de identificador	8 (forte) / 4 (fraco)	8	Forte: valor de cookie de 1ª parte enviado a terceiro, ou mesmo ID enviado a ≥ 2 terceiros. Fraco: parâmetro típico de sync (<code>uid</code> , <code>puid</code> ...) ou redirecionamento 3xx entre terceiros em pixel.
Bounce tracking	6	6	Domínio intermediário (3xx ou redirecionamento client-side com permanência < 4 s) que não é origem nem destino da navegação.
Storage HTML5 em frame de 3ª parte	4	4	Alternativa a cookies de 3ª parte quando estes são bloqueados.
Indicadores de hijacking	15 (alto) / 8 (médio) / 3 (baixo)	15	Alto: função nativa sobrescrita, keylogger de 3ª parte, ou WebSocket + polling para terceiros. Médio: WebSocket ou polling persistente para terceiro. Baixo: muitos globais novos ou EventSource.

Conceito: $A \geq 85 \cdot B \geq 70 \cdot C \geq 50 \cdot D \geq 30 \cdot E < 30$.

Como comparar com o Blacklight

O Blacklight (The Markup) **não emite nota numérica**: ele lista indicadores e compara cada um com a média dos 100 mil sites mais populares (Tranco). A comparação, portanto, é feita indicador a indicador:

Blacklight	Critério equivalente no plugin
Ad trackers (N)	Rastreadores conhecidos (categorias <i>advertising</i> , <i>analytics</i> , <i>identity</i>)
Third-party cookies (N)	Cookies de 3ª parte (snapshot do cookie jar)
Canvas fingerprinting	Fingerprinting ≥ "provável" com <code>canvas.likely > 0</code>
Session recording	Rastreador da categoria <i>session-recording</i>
Key logging	Listener de teclado por script de 3ª parte em <code>document</code>
Facebook pixel	Rastreador com owner "Meta (Facebook pixel)"
Google Analytics remarketing	Domínios <code>doubleclick</code> / <code>googlesyndication</code> / <code>googleadservices</code>

Fontes esperadas de divergência (a serem explicadas caso a caso no relatório, com referência ao HAR):

- Interação.** O Blacklight rola a página e clica em alguns links; o plugin observa apenas o que o usuário fez. Rastreadores carregados sob demanda podem aparecer só em um dos lados.
- Consentimento (LGPD/GDPR).** O Blacklight não aceita banners de cookies; se o usuário aceitou, o plugin verá mais rastreadores.
- Lista de domínios.** O Blacklight usa a lista do DuckDuckGo Tracker Radar (milhares de domínios); a lista interna do plugin é curada e menor. Domínios "não listados" do plugin podem ser rastreadores para o Blacklight, e vice-versa.
- Localização.** O Blacklight roda a partir dos EUA; anúncios e parceiros de RTB variam por região.
- Momento.** Os scripts de terceiros mudam ao longo dos dias; os dois relatórios devem ser produzidos na mesma data sempre que possível.